Clase 256 — Fundamentos de ingeniería social

> Parte: **12 — OSINT e ingeniería social** · Fuente: *Social Engineering: The Science of Human Hacking* (C. Hadnagy) · *Influence* (R. Cialdini) ⏱️ Duración estimada: **100 min** · Nivel: **Intermedio**

🎯 Objetivo

Comprender la ingeniería social como disciplina: los principios psicológicos que la hacen efectiva, su marco ético-legal y su ciclo de ataque. El alumno terminará capaz de explicar por qué funciona la manipulación, reconocer los principios de influencia en escenarios reales y sentar las bases para diseñar simulacros autorizados y programas de concienciación.

⚖️ Nota ética

La ingeniería social ofensiva —engañar a personas para obtener acceso o información— **solo es lícita con permiso explícito y por escrito** (alcance, objetivos, reglas de enfrentamiento, ventana temporal y contacto de escalado). Nunca practiques con personas sin su consentimiento o el de su organización. Toda esta clase apunta a defender y a probar de forma autorizada.

> 🔗 **Continuación en la Parte 21:** la psicología de la manipulación se profundiza en la clase 372 y el marco de inteligencia y contrainteligencia en la 371.

📚 Resultados de aprendizaje

Al finalizar, el alumno podrá:

1. **Definir** ingeniería social y ubicarla en la cadena de ataque (MITRE ATT&CK).
2. **Explicar** los seis principios de influencia de Cialdini con ejemplos.
3. **Describir** el ciclo de un ataque de ingeniería social (información, gancho, ejecución, salida).
4. **Diferenciar** vectores: phishing, vishing, smishing, pretexting, tailgating, baiting.
5. **Aplicar** un marco ético y de reporte a cualquier simulacro autorizado.

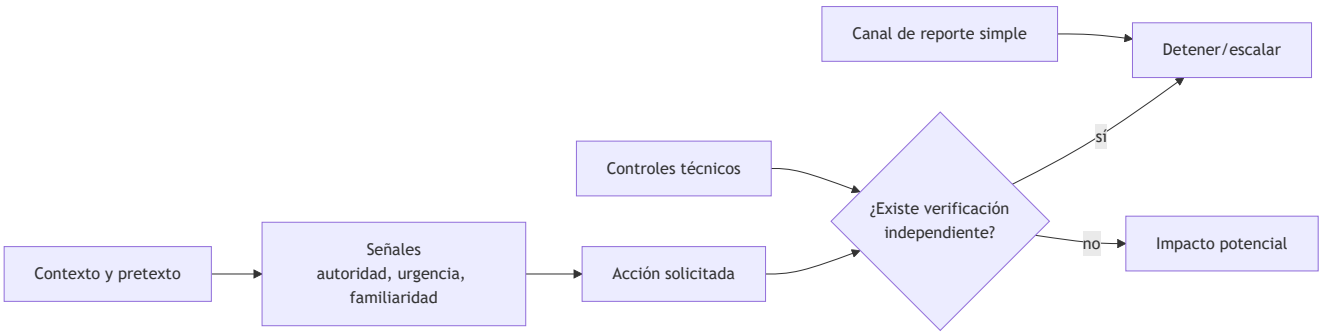
🗺️ Temas

#	Tema	Por qué importa
1	Qué es la ingeniería social	El humano como superficie de ataque
2	Principios de Cialdini	Explican por qué cae la gente
3	Ciclo de ataque SE	Estructura una operación autorizada
4	Vectores y taxonomía	Cada canal tiene su técnica
5	Sesgos cognitivos	Palancas de la manipulación
6	Marco ético y legal	Frontera entre prueba y delito
7	Del OSINT al pretexto	La información habilita el engaño

🧠 Explicación en profundidad

La ingeniería social explota un contexto, no una supuesta ingenuidad

Una persona decide con información incompleta, presión temporal, normas de ayuda y señales de autoridad. Un atacante diseña el contexto para que una acción peligrosa parezca coherente: pagar una factura, restablecer una cuenta, compartir un código o abrir un documento. Culpar a la víctima oculta fallos del sistema: procesos que permiten una sola aprobación, canales sin verificación y autenticadores que pueden retransmitirse.



El diagrama muestra que la defensa no depende solo de «reconocer señales». Inserta verificación independiente antes de una acción irreversible y facilita detenerse sin castigo. Una llamada que conoce datos reales sigue necesitando devolución a un número oficial; una solicitud de pago exige doble control; un login usa autenticación resistente al phishing.

Principios de influencia sin convertirlos en receta

Autoridad, urgencia, reciprocidad, consistencia, afinidad y prueba social ayudan a analizar mensajes, pero no son botones universales ni explican por completo la conducta. El resultado depende de rol, cultura, carga, canal y consecuencias percibidas. La educación debe enseñar a verificar procesos, no a desconfiar de toda interacción ni a memorizar una lista de trucos.

Simulación ética y reducción de daño

Una simulación autorizada define propósito, población, aprobaciones, datos recolectados, soporte, exclusiones y parada de emergencia. No solicita contraseñas reales, no usa temas traumáticos, salud, despido o crisis personales, y no avergüenza individuos. Se mide el proceso: reporte, escalamiento y resistencia técnica. Las cifras de clic no comparan limpiamente equipos con roles y exposición diferentes.

Caso razonado: cambio de cuenta bancaria

Un correo auténtico de un proveedor comprometido solicita cambiar la cuenta de pago. No contiene faltas ni dominio parecido; la formación basada en «buscar errores» falla. El control efectivo es verificar cambios financieros por un canal previamente registrado y requerir doble aprobación. El incidente se reporta sin culpar al empleado que recibió un mensaje contextualizado.

📓 Glosario operativo

Término	Definición útil
Pretexto	Historia diseñada para justificar identidad, urgencia y solicitud.
Canal independiente	Medio de verificación no proporcionado por la propia solicitud.
BEC	Compromiso o suplantación de correo para inducir acciones de negocio.
Simulación	Ejercicio autorizado con objetivos, límites y protección de participantes.
Culpa a la víctima	Enfoque que atribuye el fallo a la persona e ignora controles del sistema.

✅ Criterio de dominio

Existe dominio cuando el alumno descompone un escenario en contexto, señales, acción e impacto; diseña controles técnicos y de proceso; y propone una simulación que mide aprendizaje sin capturar secretos ni dañar a participantes.

📖 Definiciones y características

- **Ingeniería social:** manipulación de personas para que realicen acciones o revelen información. Característica: explota confianza y emoción, no fallos técnicos.
- **Principio de autoridad:** tendemos a obedecer a figuras de autoridad. Característica: el pretexto "soy de IT/dirección" es potente.
- **Prueba social:** hacemos lo que hacen los demás. Característica: "todos ya lo hicieron" reduce resistencia.
- **Escasez/urgencia:** valoramos lo escaso y actuamos ante la premura. Característica: acorta el pensamiento crítico.
- **Reciprocidad:** devolvemos favores. Característica: un pequeño gesto previo abre la puerta.
- **Pretexto:** historia falsa creíble que justifica la petición. Característica: se nutre del OSINT previo.
- **Elicitación:** obtener información sin preguntarla directamente. Característica: conversación aparentemente inocua.

🧰 Herramientas y preparación

- **Marco documental:** plantilla de *Rules of Engagement* (alcance, objetivos, límites, escalado) y autorización firmada.
- **Fuentes de estudio:** libros de Hadnagy y Cialdini (referencia, no copia); casos públicos de la SECBAG/DEF CON SECTF.
- **Registro:** diario de operación para documentar cada interacción de un simulacro autorizado.
- **Este es un módulo conceptual:** la práctica ofensiva real llega en 257–258, siempre autorizada.
- **Recordatorio:** sin permiso escrito no hay ejercicio ofensivo; aquí se estudia y se planifica.

🧪 Laboratorio guiado (ejercicio aplicado)

Análisis de casos y diseño de un marco ético, sin manipular a nadie.

1. Toma tres casos públicos de ingeniería social (p. ej. incidentes divulgados) y clasifica su vector.
2. Para cada caso, identifica qué **principios de Cialdini** se explotaron y subráyalos.
3. Reconstruye el **ciclo de ataque**: qué OSINT tuvieron, qué pretexto usaron, cómo ejecutaron y salieron.
4. Redacta una plantilla de *Rules of Engagement* para un simulacro autorizado (alcance, límites, no-hacer).
5. Diseña un pretexto **ético** de laboratorio para probar concienciación (sin datos reales de terceros).
6. Define métricas de éxito defensivas: tasa de reporte, tiempo de detección, no solo "cuántos cayeron".
7. Escribe la cláusula de escalado: qué hacer si alguien sufre estrés o se compromete algo real.

✍️ Ejercicios

1. Empareja cada principio de Cialdini con un ejemplo de correo o llamada.
2. Explica la diferencia entre elicitación y interrogatorio.
3. Analiza un correo de phishing real (recibido) e identifica sus palancas psicológicas.
4. Redacta unas Rules of Engagement completas para un engagement ficticio.
5. Diseña 3 métricas defensivas que midan resiliencia, no solo víctimas.
6. Debate: ¿dónde está la línea entre un simulacro legítimo y una manipulación dañina?

📝 Reto verificable

Entrega un **plan de simulacro de ingeniería social autorizado**: objetivos, vectores, pretexto ético, Rules of Engagement, métricas defensivas y plan de escalado. **Criterio de aceptación:** el plan incluye autorización explícita, límites claros ("qué no se hará"), protección de las personas y métricas orientadas a mejorar la defensa.

⚠️ Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
Simulacro percibido como "trampa" hostil	Faltó enfoque educativo. Diseña para enseñar, no para humillar.
Sin autorización escrita	Riesgo legal grave. Nunca ejecutes sin permiso firmado.
Métrica solo de "clics"	Mide resiliencia: tasa de reporte y tiempo de detección también.
Pretexto con datos reales de terceros	Riesgo de privacidad. Usa datos ficticios en pruebas de concienciación.
Personas dañadas emocionalmente	No hubo plan de cuidado. Incluye escalado y debrief de apoyo.

❓ Preguntas frecuentes

❓ **¿La ingeniería social es "hacking"?** Sí, es hacking del factor humano. No requiere exploits técnicos; explota psicología, y suele ser el camino más fácil al objetivo.

❓ **¿Por qué caen incluso personas técnicas?** Porque los principios de influencia operan bajo el pensamiento rápido y emocional; el conocimiento técnico no inmuniza contra la urgencia o la autoridad.

❓ **¿Necesito permiso para un simulacro interno?** Sí, autorización de la dirección y un marco documentado. Sin él, incluso un ejercicio "bienintencionado" puede ser ilegal o dañino.

🔗 Referencias

- Hadnagy, C. *Social Engineering: The Science of Human Hacking*. Wiley.
- Cialdini, R. *Influence: The Psychology of Persuasion*.
- MITRE ATT&CK — Phishing (T1566). https://attack.mitre.org/techniques/T1566/
- Social Engineering Framework (Social-Engineer LLC). https://www.social-engineer.org/framework/
- ENISA — Awareness materials. https://www.enisa.europa.eu/

📥 Material descargable

- 📄 Guía en PDF — versión imprimible de esta clase.
- 🎞️ Presentación (PPTX) — deck para proyectar en clase.

⬅️ Clase anterior

Clase 255 — Automatización de OSINT: SpiderFoot y Maltego

➡️ Siguiente clase

Clase 257 — Pretexting y vishing